

ZERO-TRUST CYBERSECURITY INFRASTRUCTURE DOSSIER

Classification: Enterprise Security Operations | Doc Ref: SEC-ENG-774

1. ZERO-TRUST PERIMETER AND IDENTITY ATTESTATION

Traditional castle-and-moat perimeter security is fundamentally incapable of neutralizing insider threats, credential compromise, and lateral network traversal. This architecture mandates zero-trust verification: every request, whether originating inside or outside the corporate network, must be explicitly authenticated, authorized, and encrypted.

Workload identity attestation is enforced through short-lived cryptographic tokens issued via OpenID Connect (OIDC) integrated with hardware TPM 2.0 chips on host nodes. Context-aware access policies evaluate device posture, geographic anomaly scores, and endpoint threat telemetry before granting transient access rights.

2. MUTUAL TLS (mTLS) ENCRYPTION AND SERVICE-TO-SERVICE AUTH

All intra-cluster and inter-cluster traffic is encrypted using TLS 1.3 with ChaCha20-Poly1305 and AES-256-GCM cipher suites. Ephemeral client and server certificates are rotated automatically every 24 hours via automated service mesh sidecars, eliminating risks associated with stale credentials.

3. CRYPTOGRAPHIC ROOT OF TRUST AND HSM KEY LIFECYCLE

All primary cryptographic keys, master certificate authorities, and database encryption keys are generated and stored within FIPS 140-3 Level 3 validated Hardware Security Modules (HSMs). Key material never leaves the secure cryptographic boundary in plaintext.

Key rotation schedules are strictly automated: root master keys rotate every 365 days; intermediate signing keys rotate every 90 days; data encryption keys (DEKs) are envelope-encrypted by Key Encryption Keys (KEKs) and rotated per customer data boundary.

4. RUNTIME CONTAINER DEFENSE AND EPBF SECURITY OBSERVABILITY

Runtime security monitoring leverages eBPF probes in the Linux kernel to intercept system calls (e.g., `execve`, `connect`, `ptrace`) in real time. Anomalous binary execution, unauthorized socket binding, or file integrity modifications trigger immediate container isolation and forensic memory snapshots.

5. INCIDENT RESPONSE WORKFLOWS AND AUDIT REMEDIATION ROADMAP

The cybersecurity engineering council directs implementation of the following enterprise hardening protocols:

- Enforce Phishing-Resistant FIDO2/WebAuthn multi-factor authentication across all privileged access vectors.
- Deploy continuous Automated Red Team (ART) adversarial simulation agents across multi-cloud infrastructure.
- Implement dynamic data loss prevention (DLP) filters intercepting API payloads containing PII/PCI strings.
- Complete SOC 2 Type II, ISO 27001:2022, and FedRAMP High certification renewals annually.
- Maintain immutable append-only SIEM audit logs with 365-day retention in write-once-read-many (WORM) storage.